

REPORT S9/L5

IDENTIFICAZIONE E ANALISI DI IOC



File analizzato:	Cattura_U3_W1_L5.pcapng
Tool utilizzati:	Wireshark, tshark
Data:	05/06/2026

INDICE

0 Introduzione

1 Metodologia di analisi

2 Indicatori di compromissione (IOC) identificati

IOC #1 — Host Announcement METASPLOITABLE

IOC #2 — Scansione TCP Connect (nmap -sT -p 1-1024)

IOC #3 — 12 porte aperte con servizi vulnerabili

3 Ipotesi sui vettori di attacco

4 Azioni raccomandate

A) Isolare il target e bloccare l'IP attaccante

B) Controllare i log di autenticazione del target

C) Disabilitare i servizi obsoleti (rexec, rlogin, rsh, Telnet)

D) Implementare firewall con principio del minimo privilegio

E) Implementare IDS/IPS

F) Applicare patch MS17-010 per EternalBlue su SMB

0. INTRODUZIONE

Obiettivo dell'esercitazione

Per questa esercitazione pratica mi e' stato fornito un file di cattura di rete (**Cattura_U3_W1_L5.pcapng**) acquisito con Wireshark. Il mio obiettivo era analizzare il traffico catturato per:

1. **Identificare gli IOC** presenti nella cattura, ovvero le evidenze concrete di un attacco in corso.
2. **Ipotizzare i potenziali vettori di attacco** che l'attaccante potrebbe utilizzare sulla base di quanto osservato.
3. **Raccomandare azioni** concrete per ridurre l'impatto dell'attacco attuale e prevenire attacchi futuri simili.

Contesto e strumenti utilizzati

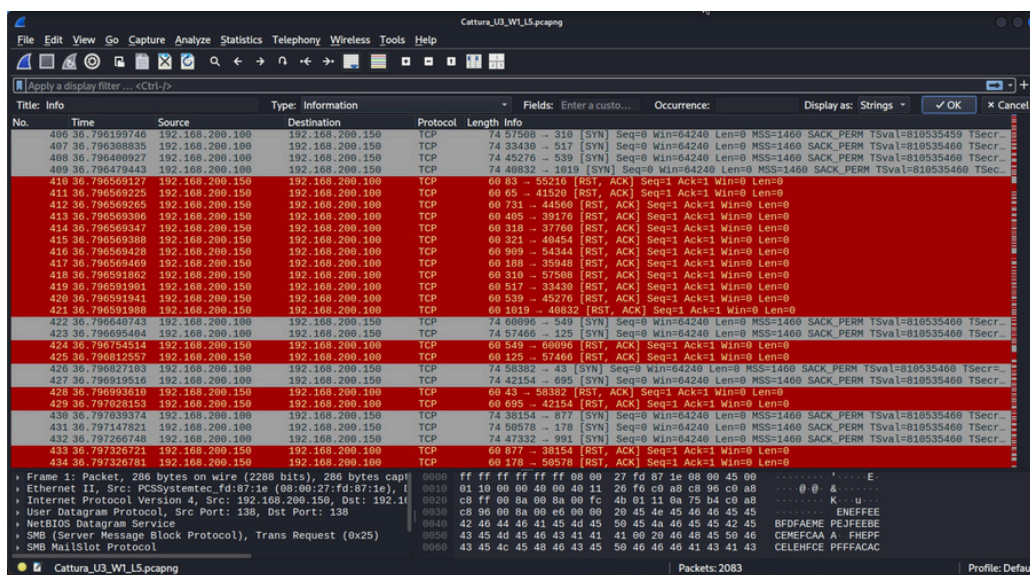
Ho condotto l'analisi su Kali Linux utilizzando principalmente **Wireshark** per l'ispezione visiva e interattiva dei pacchetti, integrato con **tshark**. Questo approccio mi ha permesso sia di avere una visione d'insieme del traffico, sia di estrarre dati numerici precisi per supportare le mie conclusioni con evidenze concrete.

Prima ancora di applicare qualsiasi filtro, la sola apertura del file in Wireshark ha fornito un segnale visivo immediato molto eloquente: quasi l'intero traffico appariva colorato di rosso, il che in Wireshark indica una massiccia presenza di pacchetti RST,ACK — connessioni TCP rifiutate. Questa prima impressione visiva mi ha orientato immediatamente verso l'ipotesi di una scansione sistematica delle porte.

1. METODOLOGIA DI ANALISI

1.1 Prima osservazione — Vista generale del traffico

Aprendo il file in Wireshark, la prima cosa che ho notato e' la colorazione quasi interamente rossa della lista pacchetti. In Wireshark il rosso indica pacchetti **RST, ACK** — connessioni TCP rifiutate. Questo pattern cosi' uniforme e' gia' un segnale di allarme: in una comunicazione normale si vedrebbe una varietà di colori. La presenza quasi esclusiva di RST mi ha suggerito immediatamente un comportamento di scansione automatizzata.



Screenshot 1 — Vista generale del pcap in Wireshark. Il rosso pervasivo indica una massiccia sequenza di RST,ACK (porte chiuse), interrotta da pacchetti bianchi SYN (tentativi di connessione). In basso e' visibile traffico SMB/NetBIOS nel frame 1.

1.2 Filtri applicati per l'analisi

Per isolare i diversi tipi di pacchetti ho usato i seguenti filtri Wireshark:

```
# Porte APERTE — mostra solo SYN-ACK inviati dal target:
tcp.flags.syn == 1 && tcp.flags.ack == 1

# Porte CHIUSE — mostra solo RST,ACK dal target:
tcp.flags.reset == 1

# Soli SYN — tentativi di connessione dallo scanner:
tcp.flags.syn == 1 && tcp.flags.ack == 0
```

2. INDICATORI DI COMPROMISSIONE (IOC) IDENTIFICATI

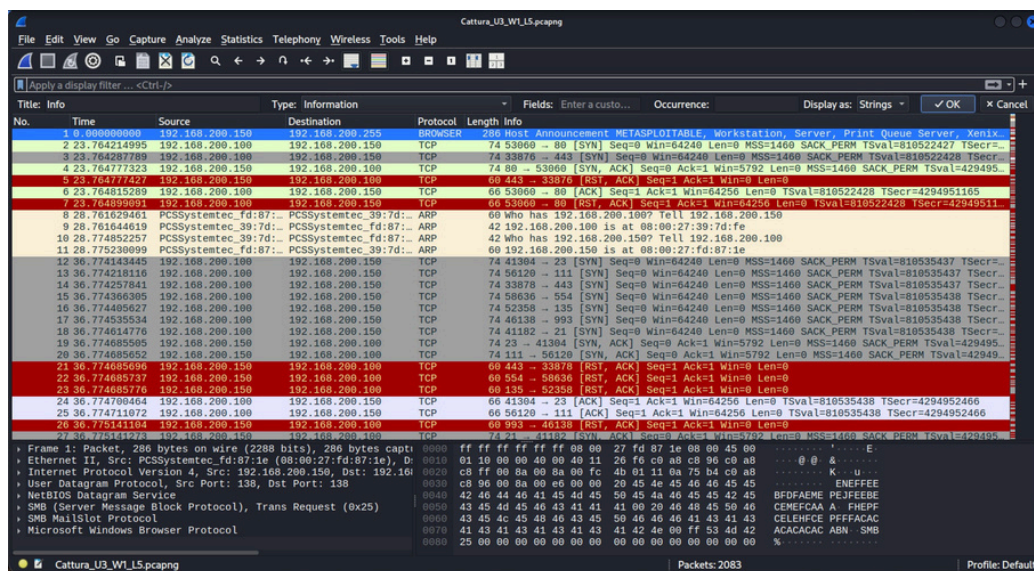
IOC #1 — Host Announcement: METASPLOITABLE

GRAVITA': CRITICA — Il sistema rivela pubblicamente la propria identità sulla rete

Come si evince dallo screen che segue, il primo pacchetto (frame 1, protocollo BROWSER) e' un Host Announcement inviato da 192.168.200.150 in broadcast. Il contenuto del messaggio recita testualmente:

```
Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix...
```

Il sistema target si sta auto-annunciando sulla rete con il nome **METASPLOITABLE**. Chiunque ascolti il traffico broadcast saprà immediatamente che quel sistema e' una distribuzione Linux deliberatamente vulnerabile. Anche senza la scansione nmap, questo annuncio sarebbe sufficiente a identificare il bersaglio e a orientare l'attacco.



Screenshot 2 — Vista dall'inizio della cattura. Il frame 1 mostra il messaggio BROWSER con 'Host Announcement METASPLOITABLE'. Sono visibili anche i pacchetti ARP (frames 8-11) con cui i due host si scambiano i MAC address prima dell'inizio della scansione vera e propria.

IOC #2 — Scansione TCP Connect (nmap -sT) delle porte 1-1024

GRAVITA': ALTA — Ricognizione attiva e sistematica della rete in corso

L'analisi quantitativa tramite tshark mi ha permesso di confermare con precisione il tipo e il range della scansione. Come si può notare dallo screen 3 che segue, ci sono SYN inviati da 192.168.200.100 verso porte comprese tra 1 e 1024, esattamente le porte well-known. Lo screenshot che segue mostra la fase centrale della scansione: una raffica uniforme di RST,ACK prodotta dal target in risposta ai SYN.

1244	36.837936850	192.168.200.150	192.168.200.100	TCP	60 642 → 51434 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1245	36.837936930	192.168.200.150	192.168.200.100	TCP	60 756 → 42724 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1246	36.837936977	192.168.200.150	192.168.200.100	TCP	60 865 → 58906 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1247	36.837937017	192.168.200.150	192.168.200.100	TCP	60 349 → 56824 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1248	36.837937057	192.168.200.150	192.168.200.100	TCP	60 605 → 55968 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1249	36.837937099	192.168.200.150	192.168.200.100	TCP	60 200 → 48132 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1250	36.837937138	192.168.200.150	192.168.200.100	TCP	60 88 → 47594 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1251	36.837937179	192.168.200.150	192.168.200.100	TCP	60 451 → 44292 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1252	36.837991413	192.168.200.150	192.168.200.100	TCP	60 815 → 47884 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1253	36.837991463	192.168.200.150	192.168.200.100	TCP	60 48 → 36060 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1254	36.837991502	192.168.200.150	192.168.200.100	TCP	60 162 → 42224 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1255	36.837991541	192.168.200.150	192.168.200.100	TCP	60 875 → 50746 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1256	36.837991587	192.168.200.150	192.168.200.100	TCP	60 1022 → 38352 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1257	36.837991626	192.168.200.150	192.168.200.100	TCP	60 225 → 45820 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1258	36.837991672	192.168.200.150	192.168.200.100	TCP	60 454 → 56484 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1259	36.838062881	192.168.200.150	192.168.200.100	TCP	60 37 → 42742 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1260	36.838062962	192.168.200.150	192.168.200.100	TCP	60 118 → 44816 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1261	36.838063000	192.168.200.150	192.168.200.100	TCP	60 136 → 41010 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1262	36.838063041	192.168.200.150	192.168.200.100	TCP	60 134 → 59516 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1263	36.838063080	192.168.200.150	192.168.200.100	TCP	60 441 → 56112 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1264	36.838063120	192.168.200.150	192.168.200.100	TCP	60 910 → 44332 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1265	36.838063160	192.168.200.150	192.168.200.100	TCP	60 480 → 55668 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1266	36.838063200	192.168.200.150	192.168.200.100	TCP	60 744 → 57498 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1267	36.838064938	192.168.200.150	192.168.200.100	TCP	60 161 → 58808 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1268	36.838084976	192.168.200.150	192.168.200.100	TCP	60 774 → 47654 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1269	36.838085017	192.168.200.150	192.168.200.100	TCP	60 608 → 37098 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1270	36.838085056	192.168.200.150	192.168.200.100	TCP	60 658 → 48190 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1271	36.838085096	192.168.200.150	192.168.200.100	TCP	60 614 → 48366 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1272	36.838085135	192.168.200.150	192.168.200.100	TCP	60 140 → 47864 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1273	36.838085182	192.168.200.150	192.168.200.100	TCP	60 246 → 42852 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1274	36.838147340	192.168.200.150	192.168.200.100	TCP	60 952 → 45948 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
1275	36.838147388	192.168.200.150	192.168.200.100	TCP	60 366 → 41254 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Screenshot 3 — Fase centrale della scansione: RST,ACK a raffica da 192.168.200.150 verso 192.168.200.100. L'uniformita' del pattern e la velocita' con cui si susseguono i pacchetti confermano l'uso di uno scanner automatico come nmap.

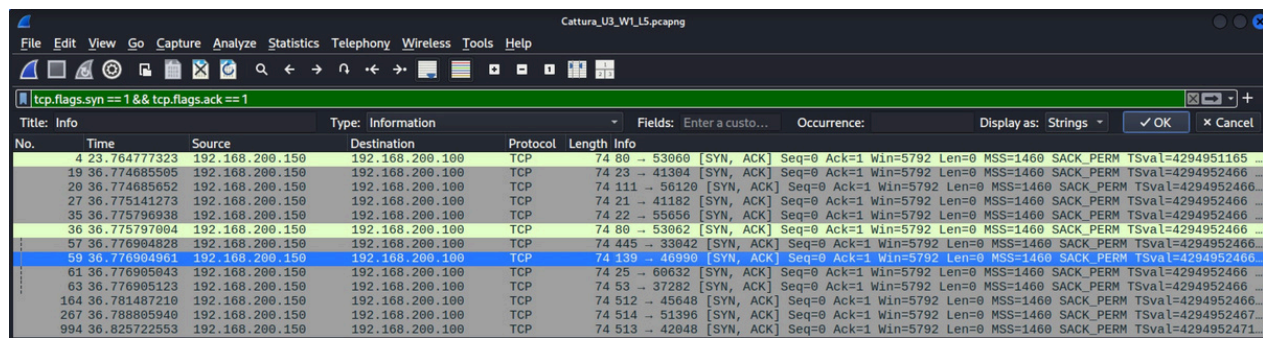
Ho poi verificato il **tipo di scansione** analizzando la sequenza dei flag TCP su una porta aperta (es. porta 80): ho osservato SYN, SYN-ACK, ACK, RST, ovvero il three-way handshake completato prima della chiusura. Questo e' il comportamento caratteristico della **scansione -sT (TCP Connect)**, diversa dalla piu' silenziosa -sS in cui il RST verrebbe inviato immediatamente dopo il SYN-ACK.

Comando ricostruito	nmap -sT -p 1-1024 192.168.200.150
SYN inviati	1026 (range 1-1024 + 2 ritrasmissioni)
Tipo scansione	TCP Connect (-sT): handshake completato
Durata totale	~13 secondi

IOC #3 — 12 porte aperte con servizi obsoleti e criticamente vulnerabili

GRAVITA': CRITICA — Superficie di attacco estremamente ampia

Applicando il filtro `tcp.flags.syn==1 && tcp.flags.ack==1` ho isolato i soli pacchetti SYN-ACK inviati dal target, che corrispondono alle porte effettivamente aperte. Il terzo screenshot mostra il risultato: 12 porte aperte, molte delle quali corrispondono a servizi obsoleti o intrinsecamente insicuri.



Screenshot 3 — Filtro `tcp.flags.syn==1 && tcp.flags.ack==1` applicato in Wireshark. Ci mostra solo i 12 pacchetti SYN-ACK inviati dal target. Le porte sorgente identificano i servizi aperti: 80 (HTTP), 23 (Telnet), 111 (RPC), 22 (SSH), 21 (FTP), 445 (SMB), 139 (NetBIOS), 25 (SMTP), 53 (DNS), 512 (rexec), 513 (rlogin), 514 (rsh).

Porta	Servizio	Rischio	Considerazioni
21	FTP	ALTO	Trasmette credenziali in chiaro. Vulnerabile a brute force e sniffing.
22	SSH	MEDIO	Sicuro se configurato correttamente. Target frequente di brute force.
23	Telnet	CRITICO	Completamente non cifrato. Obsoleto. Va disabilitato immediatamente. Mail
25	SMTP	MEDIO	server. Verificare open relay e user enumeration (VRFY/EXPN).
53	DNS	MEDIO	DNS server. Verificare se e' open resolver o soggetto a zone transfer.
80	HTTP	MEDIO	Web server. Da analizzare per vulnerabilita' applicative.
111	RPC	ALTO	Remote Procedure Call. Spesso sfruttato per privilege escalation.
139	NetBIOS	ALTO	File sharing legacy. Permette null session e enumerazione utenti.
445	SMB	CRITICO	Vulnerabile a EternalBlue/MS17-010. Bersaglio preferito dai ransomware.
512	rexec	CRITICO	Remote execution obsoleto. Autenticazione debole o assente.
513	rlogin	CRITICO	Remote login senza cifratura. Completamente insicuro.
514	rsh	CRITICO	Remote shell. Accesso basato solo su IP in alcune configurazioni.

3. IPOTESI SUI VETTORI DI ATTACCO

Sulla base degli IOC identificati ho ipotizzato i vettori piu' probabili che l'attaccante potrebbe sfruttare in una fase successiva alla ricognizione gia' completata.

Fase attuale: Ricognizione completata

La scansione nmap -sT -p 1-1024 rappresenta la fase di ricognizione attiva. Ho notato che l'uso della TCP Connect scan invece della piu' silenziosa SYN scan (-sS) potrebbe indicare che l'attaccante non dispone di privilegi root sulla propria macchina oppure che non teme di essere rilevato.

Vettore 1 — SMB porta 445 (Probabilita': MOLTO ALTA)

La porta 445 aperta su Metasploitable e' il vettore piu' critico. Il servizio e' vulnerabile all'exploit **EternalBlue (MS17-010)**, che permette l'esecuzione di codice remoto con privilegi SYSTEM senza autenticazione. E' lo stesso exploit sfruttato da WannaCry nel 2017, che abbiamo analizzato in precedenza.

Vettore 2 — Servizi r* porte 512-514 (Probabilita': ALTA)

La triade rexec/rlogin/rsh e' la firma quasi certa di Metasploitable. In alcune configurazioni questi servizi accettano connessioni basandosi solo sull'IP sorgente, senza richiedere password. Un attaccante sulla stessa rete locale potrebbe ottenere una shell root senza alcuna credenziale.

Vettore 3 — Telnet porta 23 (Probabilita': MEDIA)

Telnet trasmette tutto in chiaro, credenziali incluse. Chiunque abbia accesso alla rete puo' intercettare le sessioni con un semplice sniffer. Su Metasploitable le credenziali di default (msfadmin:msfadmin) sono pubblicamente note.

Fase	Azione ipotizzata	MITRE ATT&CK
1. Ricognizione	Scansione nmap -sT -p 1-1024 (GIA' AVVENUTA)	T1046 — Network Service Discovery
2. Identificazione	Host Announcement METASPLOITABLE intercettato	T1590 — Gather Victim Network Info
3. Accesso	Exploit EternalBlue su 445 oppure rlogin senza auth	T1210 — Exploitation of Remote
4. Esecuzione	Shell remota root tramite rsh o payload Metasploit	Services T1059 — Command and
5. Persistenza	Backdoor, SSH key injection, modifica /etc/passwd	Scripting
		Interpreter T1136 — Create Account

4. AZIONI RACCOMANDATE

Le seguenti raccomandazioni sono divise tra azioni immediate da intraprendere subito per limitare i danni dell'attacco in corso, e misure strutturali per prevenire situazioni simili in futuro.

A) Azione immediata - Isolare 192.168.200.150 e bloccare 192.168.200.100

La priorit  assoluta   impedire che l'attaccante proceda oltre la ricognizione. Aggiungerei immediatamente una regola sul firewall per bloccare il traffico proveniente da 192.168.200.100 e isolerei il sistema target dalla rete fino al completamento delle verifiche. Il comando sarebbe:

```
sudo iptables -A INPUT -s 192.168.200.100 -j DROP
```

B) Verifica dei log di autenticazione del target

Un'altra azione che farei subito   andare a controllare i log di autenticazione del sistema 192.168.200.150. Dopo aver visto la scansione mi sono chiesto se l'attaccante si fosse fermato qui, o ha gi  provato a entrare? I log mi direbbero se nel frattempo sono stati fatti tentativi di login su SSH, FTP o Telnet — o peggio, se qualcuno   riuscito ad accedere.

C) Disabilitare i servizi obsoleti e inutili

I servizi rexec, rlogin, rsh e Telnet non hanno ragione di esistere su un sistema moderno. Vanno rimossi immediatamente. SSH li sostituisce tutti in modo sicuro.

D) Implementare un firewall con principio del minimo privilegio

Aprire solo le porte strettamente necessarie e solo verso gli IP autorizzati. Un sistema che non deve ricevere connessioni dall'intera LAN non dovrebbe avere porte esposte verso tutti.

E) Implementare un IDS/IPS per rilevare scansioni future

Strumenti come Snort, Suricata o Wazuh , che abbiamo studiato durante il laboratorio settimanale, sono in grado di rilevare automaticamente pattern, cio  comportamenti comuni ripetuti di scansione come quello osservato (molti SYN su porte diverse in pochi secondi) e generare alert immediati. La scansione in questo pcap sarebbe stata bloccata da qualsiasi IDS correttamente configurato.

F) Applicare patch per EternalBlue (SMB)

La vulnerabilit  MS17-010 su porta 445 ha patch disponibili da anni. Va applicata con massima priorit . Se SMB non   necessario, va disabilitato completamente.
